

SQL 注入漏洞报告（Lab6： UNION 攻击在单列中检索多个值）

1. 漏洞名称

SQL Injection（SQL 注入） — UNION 联合查询单列多值检索（字符串拼接）

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站商品分类查询功能存在 SQL 注入漏洞。攻击者通过前序探测发现，原始查询虽然有多列，但只有一列能被网页用来输出文本（即只有列 2 有效）。为了在同一列中同时读取 username 和 password，攻击者利用数据库的字符串拼接语法，将两个字段合并成一个字符串，成功在单列中提取出了完整的管理员凭证。

4. 漏洞位置

请求方式：GET /filter?category=...

漏洞参数：category

5. 漏洞复现过程

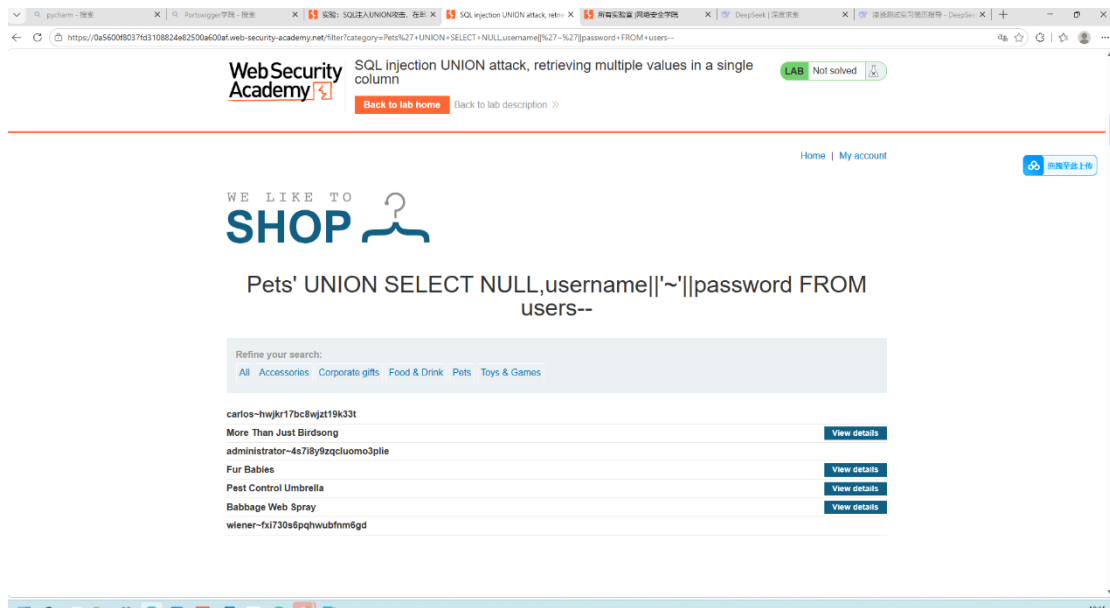
第一步：构造多字段拼接 Payload

得知只有列 2 是文本列后，无法使用 username, password 占两列。于是使用数据库拼接符（本例为 Oracle 数据库，使用 ||）进行合并。

- 测试 Payload（URL 编码前）：

text

Pets' UNION SELECT NULL, username||'~'||password FROM users—



截图 1：成功在单列中提取完整账号密码

说明：使用 `||'~'||` 拼接符，将用户名、分隔符（~）、密码合并为一个整体字符串，成功显示在了网页上。证明攻击者掌握了在有限回显位置提取复杂数据的能力。

第二步：利用窃取到的凭证尝试登录

分析回显结果，获取管理员用户名为 administrator，密码为 4s7i8y9zqcluomo3plle。访问 /login 页面。



截图 2：填写管理员凭证

(在此处插入你发的 图 2：登录页面输入框已填入 administrator 和 密码的截图)

说明：将注入获取的数据用于合法登录流程，形成闭环。

第三步：登录成功，漏洞验证完成

点击登录，成功以管理员身份进入后台。



截图 3：管理员权限验证与实验完成

(在此处插入你发的 **图 3**：页面显示“你的用户名是：管理员”，且右上角绿色“实验室已解决”的截图)

说明：验证了窃取的数据完全正确，成功接管系统权限。

第四步：漏洞原理（关键点）

原 SQL：

sql

```
SELECT * FROM products WHERE category='Pets'
```

拼接后的恶意 SQL：

sql

```
SELECT * FROM products WHERE category='Pets' UNION SELECT NULL,  
username||'~'||password FROM users--'
```

- username||'~'||password：这是这个 Lab 的核心。在 Oracle 数据库中，|| 是字符串连接符。它把三部分拼接成一个字段输出。
- 为什么用 '~'？因为如果不加分隔符，wiener 和 5v3b... 会黏在一起变成 wiener5v3b...，攻击者很难肉眼分辨出哪部分是用户名，哪部分是密码。

6. 漏洞影响

- 即使网页回显位置极其有限（只有 1 个文本列），攻击者依然可以利用数据库特性窃取多列数据。
- 直接导致管理员账号密码失窃，攻击者 **100%接管系统**。
- 真实的数据库渗透测试（Penetration Testing）中经常用到此技巧。

7. 修复建议

- ① **强制使用参数化查询（预编译）**，这是唯一的银弹。
- ② **数据库表结构信息隐藏**：前端不要直接回显数据库的列名或报错信息，统一使用 500 错误处理。
- ③ **对于不同数据库类型**：
 - MySQL 拼接使用：CONCAT(username, '~', password)
 - Oracle 拼接使用：username || '~' || password
 - SQL Server 拼接使用：username + '~' + password
 - 系统部署 WAF（Web 应用防火墙）时，应针对这些数据库特征关键字及 UNION 语法进行拦截。

8. 工具

- Google Chrome / Firefox 浏览器（直接修改 URL 参数）
- PortSwigger Web Security Academy（靶场平台）